Administração de Sistemas ASIST

Tópico 2

Business Continuity Management

Business Continuity Management

- A utilização de recursos informáticos é uma realidade[1]
- Mesmo a nível particular, a utilização dos recursos informáticos é uma realidade cada vez mais premente[2]
- Esta realidade tornou essencial o (*bom*) funcionamento dos recursos informáticos
- Mas qual o impacto consoante a tipologia do utilizador?
  - É indiferente consoante se trata de um particular ou de uma empresa?

[1] Pordata, 17/8/2020: 99,2% das empresas com 10 ou mais trabalhadores (Portugal)
[2] Pordata, 17/8/2020: 3.641.758 assinantes de acesso à Internet (Portugal)

Business Continuity Management

- Não!
- O que muda é a expectativa e celeridade necessária para a sua utilização
- Os anseios e necessidades são as mesmas, o que altera é a capacidade (ou desejo) de manter o nível de funcionamento pretendido
- Tornou-se por isso premente a criação de uma metodologia para aferir o nível de funcionamento dos sistemas informáticos, e a definição de critérios que os meçam e/ou definam

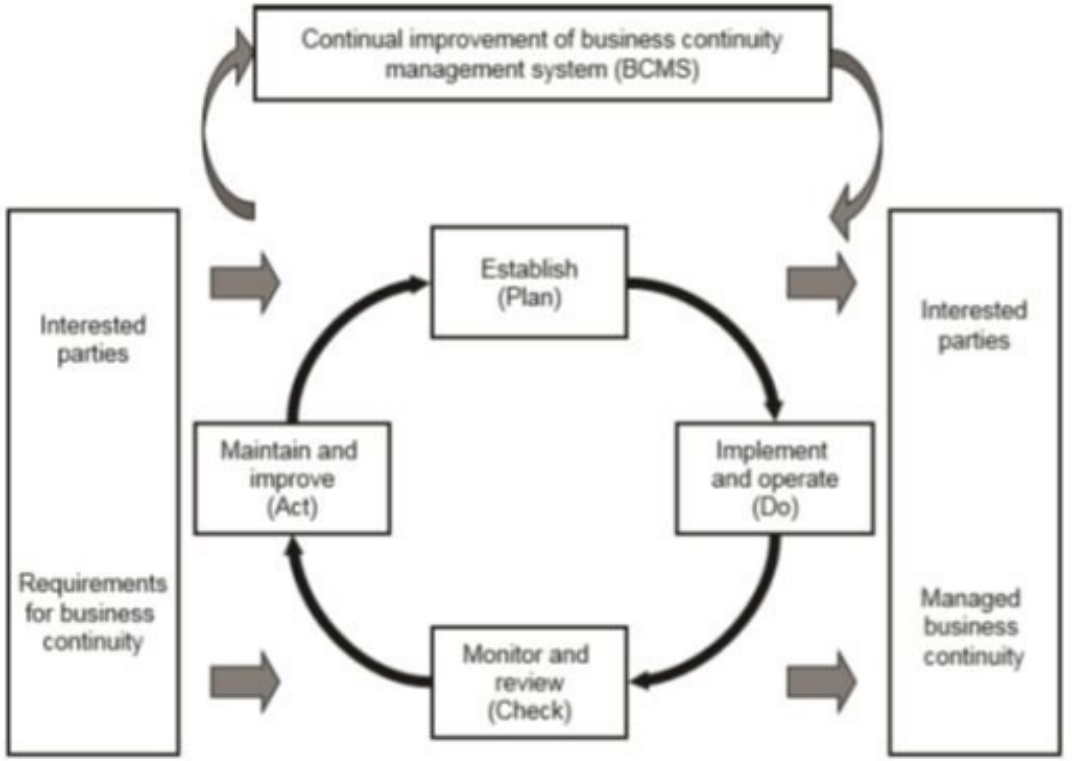
- Surgiram desta forma normas, das quais destacamos o ISO 27000

Business Continuity Management

- As normas ISO 27000, apoiadas por outras normas entre as quais a ISO 22301 e a 22313, definem critérios para manter a continuidade de negócio
  - Note-se que *negócio* deve ser entendido no sentido lato
- Elas definem regras tendo em mente organizações, mas adaptáveis à sua dimensão (que até pode ser um particular)
- O objetivo é normalizar metodologias e possibilitar desta forma critérios comuns
- Como traço comum, a necessidade de ser uma metodologia *top-down*, isto é, não faz sentido ser uma decisão individual de um só indivíduo sem o apoio dos decisores (numa organização, a gestão de topo)
- Estas normas definem o *Business Continuity Management* (BCM)

Business Continuity Management

- O modelo preconizado nas normas é o *Plan-Do-Check-Act* (PDCA)
  - Ou seja, é um modelo de contínua observação, planeamento e ação
- Como parte essencial para aplicação do modelo, integra um conjunto de critérios que devem ser cumpridos



Fonte: ISO 22301:2012

Business Continuity Management
Critérios I

- ***Maximum Tolerable Period of Disruption*** **(MTPD)**
- ***Maximum Tolerable Downtime*** **(MTD)**

- Estes dois critérios possuem um significado aproximado e definem:
  - MTPD: o tempo máximo de desempenho inferior aos requisitos da infraestrutura informática
  - MTD: o tempo máximo de inoperacionalidade da infraestrutura informática
- O objetivo é num período inferior ao definido por estes critérios a atividade e requisitos de desempenho da organização (isto é, *o negócio*) seja retomada
- Estes valores podem não ser fixos, estáticos
  - Por exemplo, pode haver um período temporal no qual é mais exigente do que noutro – por exemplo em negócios sazonais
  - Pode também haver um serviço mais premente do que outro
  - Nesse caso o BCM deve especificar todos os aplicáveis

Business Continuity Management
Critérios II

- ***Mininum Business Continuity Objective*** **(MBCO)**

- Especifica o nível mínimo de operacionalidade que deve ser mantida durante uma disrupção na infraestrutura
- Por exemplo, o serviço S1 pode não estar operacional mas o serviço S2 tem que se manter no nível de funcionamento aceitável
- O MTD/MTPD será certamente mais restrito para os serviços associados a este objetivo

Business Continuity Management

- Uma questão que se pode levantar aqui é o que é o nível de funcionamento aceitável
- Este é o nível de funcionamento (que veremos mais tarde) em termos de segurança, integridade e disponibilidade (ou seja, em termos de tempo de resposta) que é pretendido e aceite pela organização
- Designa-se este conjunto de parâmetros qualitativos e quantitativos por ***Service Level Agreement*** (**SLA**)

Business Continuity Management
Critérios I

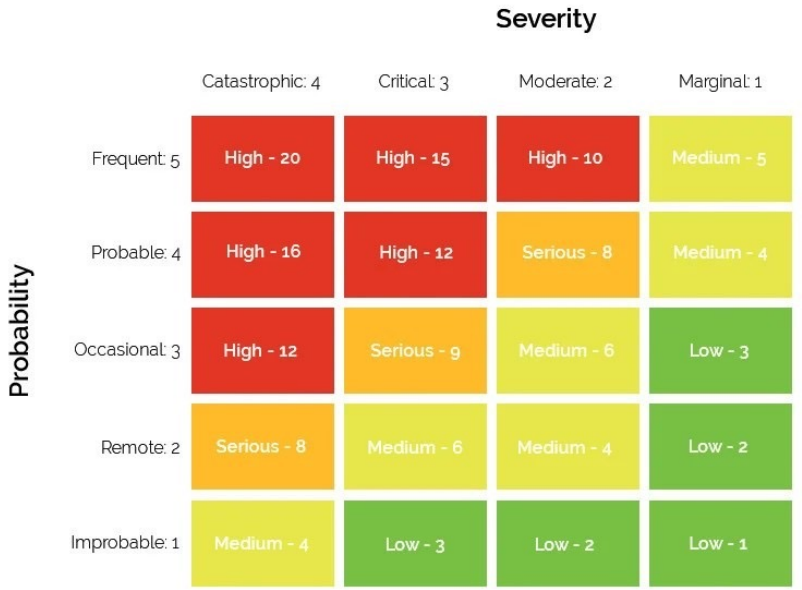
- ***Businness Impact Analysis*** **(BIA)**
  - Identifica as atividades críticas da organização e as suas dependências; permite desta forma priorizar as operações de recuperação após uma disrupção
- ***Risk Assessment*** **(RA)**
  - Constituído pelos cenários que podem afetar a continuidade de negócio, a probabilidade de ocorrerem e o seu impacto
- ***Business Continuity Plan*** **(BCP)**
  - O BCP é parte integrante do BCM e documenta os procedimentos a efetuar para responder, recuperar, retomar e restaurar a um nível pré-definido de operação após a interrupção

Business Continuity Management
Critérios II

- O ***Risk Assessment*** (**RA**) é habitualmente representado por uma matriz de risco
- Cada item tem associada uma probabilidade e um impacto (severidade) estimado; o produto destes fatores dá uma medida para o risco

Risco = Impacto x Probabilidade

- Considerando probabilidades numa escala de 1 (menos possível) a 5 (mais possível) e impacto numa escala de 1 (marginal) a 4 (catastrófico), temos



Fonte: Industry Safe

Business Continuity Management
Critérios III

- O *risk assessment* deve ser definido para todos os riscos identificados
- Pode não haver necessidade de construir a matriz de risco, mas tê-la auxilia a determinação dos riscos mais preocupantes e reduzi-los (mitigá-los)
- Mas importa que no BCM estejam definidos as ameaças riscos consideradas e a sua classificação de risco

Business Continuity Management
Critérios IV

- ***Disaster Recovery Plan*** **(DRP)**

- O DRP é também parte integrante do BCM
- Em situação normal, a infraestrutura funciona dentro dos parâmetros definidos no SLA e o BCM encarrega-se da observação (monitorização), planeamento, implementação das ações corretivas e demais atos considerados necessários
- Contudo, podem ocorrer problemas que impliquem a violação do SLA
- Mas será que violam também o MBCO ou o MTD?
  - Se o MBCO ou o MTD não são afetados, o BCM deve conter os procedimentos necessários para recuperar o SLA dos serviços em disrupção
  - Se são afetados, o DRP assume o controlo até à recuperação da situação pretendida

Business Continuity Management

- Sendo pretendida a continuidade de negócio, a elaboração do BCM deve analisar e mitigar constrangimentos potenciais
- Todas as ameaças e falhas que possam ocorrer devem ser avaliadas e, possivelmente, eliminadas – ou pelo menos mitigadas
- Comecemos por analisar os critérios SLA; deve contemplar não apenas os níveis de serviço (confidencialidade, integridade e disponibilidade) pretendidos mas também a forma de os medir e validar
- Um sistema que cumpre o SLA combinado designa-se por **sistema seguro**

Business Continuity Management

- Mas para que um sistema seja seguro, é necessário analisar e mitigar falhas que possam ocorrer
- Qual a probabilidade de falha (**P**) de um serviço?
  - O serviço depende de componentes, que por sua vez podem depender de outros componentes, etc. (veja-se como exemplo um serviço que corre num sistema, mas esse sistema depende da memória, do disco, da alimentação elétrica, etc.)
- A probabilidade de falha de um serviço dependente de vários fatores é dada pela soma das probabilidades de falhas de todos os fatores envolvidos

$$P = P_1 + P_2 + \ldots + P_N$$

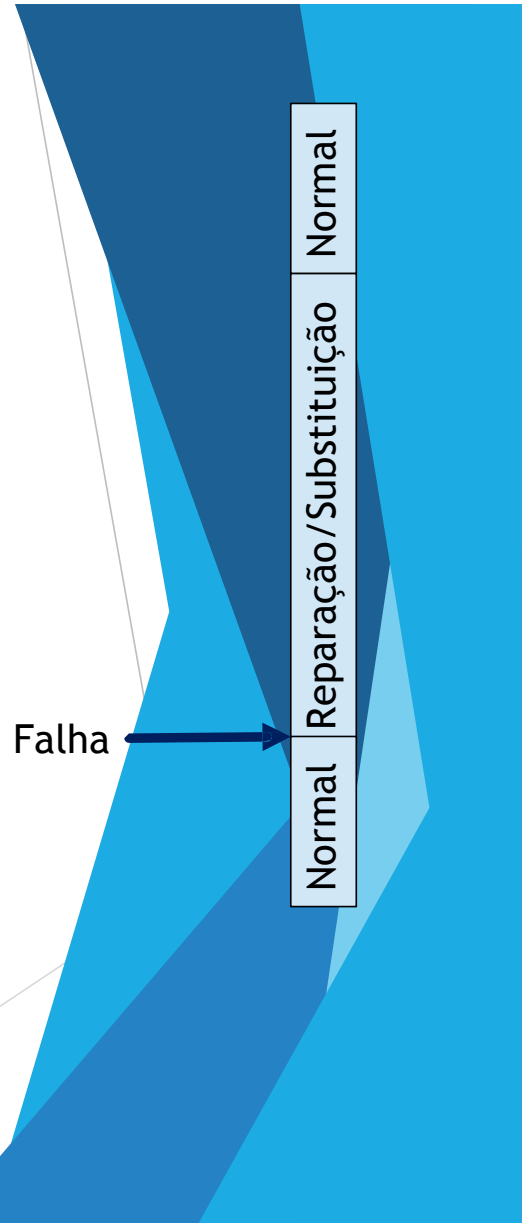
Business Continuity Management

- É contudo mais vulgar o uso do tempo médio entre falhas (***Mean Time Between Failures*** **MTBF**)
- Para o seu cálculo é tido em consideração não apenas o tempo médio para falhar (***Mean Time To Fail*** **MTTF**) mas também o tempo necessário para reparar ou substituir (***Mean Time To Repair/Replace*** **MTTR**)

$$\mathbf{MTBF = MTTF + MTTR}$$

- Com base neste valor, podemos calcular a disponibilidade de um sistema ou serviço

$$\boldsymbol{Disponibilidade} = \frac{\boldsymbol{tempo\ de\ operação\ sem\ falha}}{\boldsymbol{tempo\ de\ operação\ total}} = \frac{\boldsymbol{MTTF}}{\boldsymbol{MTTF + MTTR}} = \frac{\boldsymbol{MTTF}}{\boldsymbol{MTBF}}$$



Business Continuity Management

- O inverso do MTBF é a **taxa de falhas por hora**, representada por λ ou, se calculado para um milhão de horas, a taxa de falhas por milhão de horas (**FIT**)
- O cálculo do MTBF de um sistema ou serviço que depende de vários subcomponentes em série pode ser calculado como o inverso da soma das taxas de falha por hora (ou por milhão de horas) de cada subcomponente
- Admita-se um sistema constituído por 3 (três) componentes não redundantes
  - Componente 1: MTBF1 = 20000 → FIT1 = 1000000/MTBF1 = 50
  - Componente 2: MTBF2 = 10000 → FIT2 = 1000000/MTBF2 = 100
  - Componente 3: MTBF3 = 15000 → FIT3 = 1000000/MTBF3 = 66,67
- O cálculo do FIT do sistema completo é **FIT1 + FIT2 + FIT3 = 216,67** pelo que

$$\mathbf{MTBF_{total} = 1000000 / FIT \approx 4615,3}$$

Business Continuity Management

- Para obter uma melhor disponibilidade é essencial aumentar o MTTF e diminuir o MTTR
- O aumento do MTTF pode ser obtido através de um controlo de qualidade dos produtos/serviços
- A diminuição do MTTR nem sempre é obtido com o mesmo controlo de qualidade dos produtos/serviços – para além de ser dependente do tipo de produto/serviço em causa
- A reparação de um serviço que interrompe o seu funcionamento não é comparável com a substituição de um sistema!
- Designa-se por **alta disponibilidade** a obtenção de uma disponibilidade de 100% ou próximo desse valor

Business Continuity Management

- Entre os princípios que podem ser ativados para aumentar a disponibilidade ressalta a **redundância**
- Contudo, um aspeto a ter em conta é a total independência e autonomia dos componentes redundantes
- O cálculo do MTBF de um sistema redundante socorre-se da taxa de falhas por hora, λ, dos seus componentes
- Admita-se um sistema constituído por 3 (três) componentes redundantes mas não redundantes entre si
  - Componente 1: MTBF1 = 20000 → $\lambda 1$ = 1/MTBF1 = 0,00005
  - Componente 2: MTBF2 = 10000 → λ 2 = 1/MTBF2 = 0,001
  - Componente 3: MTBF3 = 15000 → λ 3 = 1/MTBF3 ≈ 0,000067
- O cálculo de λ do sistema completo é λ**1 x** λ**2 x** λ**3 ≈ 0,0000000000003** pelo que

$$\mathbf{MTBF_{total} = 1 / \lambda \approx 3 \times 10^{12}}$$

Business Continuity Management

- Através da **prevenção de falhas** (*Fault Avoidance*) procura-se evitar a ocorrência de falhas que coloquem em causa a continuidade de negócio
- Vários mecanismos podem ser utilizados, dos quais se destacam a monitorização e alarmística (verificação da utilização de recursos como disco, CPU, controlo da temperatura, humidade, etc.)

- O nível de **tolerância a falhas** (*Fault Tolerance*) classifica o sistema ou serviço de acordo com o seu comportamento perante uma falha de qualquer origem
  - Se mantém o funcionamento: ***Full Fault Tolerant***
  - Se ocorre uma degradação temporária: ***Gracefull Degradation***
  - Se a degradação é significativa ou prolongada: ***Fail Soft***
  - Se torna o sistema/serviço indisponível mas mantém a integridade: ***Fail Safe***

Business Continuity Management

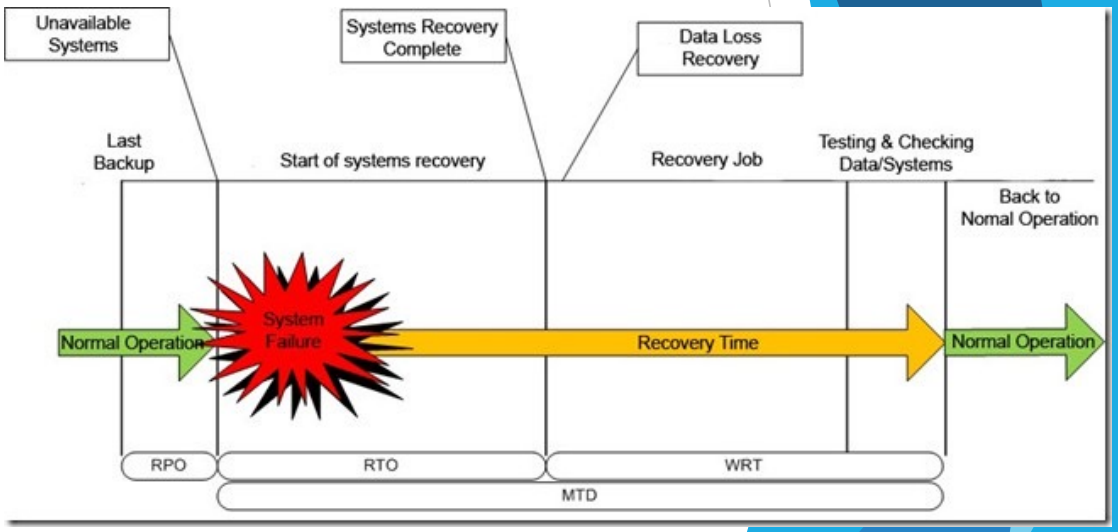
- Mesmo com recurso à redundância, note-se que podem existir componentes comuns ao sistema redundante
  - Exemplo: alimentação elétrica, sistema de controlo da redundância
- Estes componentes comuns designam-se por **SPOF** (*Single Point Of Failure*) e devem ser evitados
- Podem também existir falhas ligadas ou não a componentes físicos que implicam a indisponibilidade do sistema
  - Exemplo: vulnerabilidade no sistema operativo
- Um **CMF** (*Common-Mode Fault*) é uma falha que provoca a indisponibilidade de mais do que um componente do sistema redundante
  - Um SPOF é sempre um CMF mas o inverso não é verdade

Business Continuity Management

- Vejamos ainda com mais detalhe as componentes do MTTR para que cumpra o MTD pretendido
- A falha pode ser menor e facilmente resolvida ou mais complexa
- Importa por isso assegurar aspetos como as cópias de segurança ou equivalente, permitindo dessa forma a retoma da situação imediatamente anterior à ocorrência da falha
- Deve-se contudo notar que o MTTR só termina quando a operacionalidade está integralmente recuperada
  - Ou seja, o tempo de reposição das cópias de segurança ainda é parte integrante do MTTR

Business Continuity Management

- É mais apropriado e útil estabelecer objetivos quer do tempo médio de recuperação da funcionalidade quer do volume de perda de dados que é aceite
  - ***Recovery Time Objective*** (**RTO**) é o tempo médio de recuperação dos sistemas e infraestruturas
  - ***Recovery Point Objective*** (**RPO**) é o tempo máximo de perda de dados aceite
  - ***Work Recovery Time*** (**WRT**) é o tempo necessário para repor os dados e aplicações e testá-los



Fonte: CISSWhat? - A CISSP Review

Business Continuity Management

- Em teoria, é sempre possível arranjar uma estratégia para assegurar a continuidade de negócio
- Contudo, algumas dessas estratégias (e cujo risco de acordo com a matriz de risco identificada é considerável) podem implicar um custo desapropriado ao benefício obtido

- Torna-se por isso necessário analisar e calcular o custo da mitigação do risco face ao benefício obtido

Business Continuity Management

- Definamos um ***Asset Value*** (**AV**) que representa o valor do item em causa
- A exposição ao risco desse item é representada pelo ***Exposure Factor*** (**EF**)
- A ***Single Loss Expenditure*** (**SLE**) é obtida pela multiplicação destes dois fatores

$$SLE = AV \times EF$$

- Pode-se também obter ou calcular a probabilidade de ocorrência de um dano no bem ao longo de um ano, isto é, o ***Annualized Rate of Occurrence*** (**ARO**), o que permite calcular a ***Annualized Loss Expectancy*** (**ALE**)

$$ALE = SLE \times ARO = AV \times EF \times ARO$$

- O valor obtido deve ser comparado com o custo da ação necessária para o mitigar

Business Continuity Management

Caso 1

- Imaginemos os seguintes fatores
  - AV = 500€
  - EF = 20%
  - ARO = 3
  - SLE = 500 x 20% = 100€
  - ALE = SLE x ARO = 100 x 3 = 300€
  - A ação deve ser considerada se o seu custo for <= 300€

Caso 2

- Imaginemos os seguintes fatores
  - AV = 1000€
  - EF = 30%
  - ARO = 2
  - SLE = 1000 x 30% = 300€
  - ALE = SLE x ARO = 300 x 2 = 600€
  - A ação deve ser considerada se o seu custo for <= 600€

Business Continuity Management

- O cálculo do AV pode não ser sempre tão simples
  - Qual o valor dos dados?
- Para prever a perda de dados (o que influencia o cálculo do RPO) pode-se recorrer a diversas estratégias como por exemplo
  - *Mirroring* para local ou instalações remotas
  - Cópias de segurança
- Ambas as estratégias possuem benefícios e inconvenientes
- De notar que o RTO é ou pode ser independente da estratégia adotada
  - Mas o WRT é influenciado pela estratégia

Business Continuity Management

- *Mirroring* para local remoto
  - Pode ser síncrono ou assíncrono
  - Facilita a recuperação em caso de desastre
  - O RPO e o WRT são nulos (se for síncrono) ou muito próximo disso (se for assíncrono)
  - Implica a necessidade de garantir a confidencialidade e integridade dos dados, o que vai provocar por sua vez uma maior latência na rede com possível impacto na disponibilidade de operação (e inerentemente no SLA)

Business Continuity Management

- A cópia de segurança tem três estratégias possíveis (i)
  - Integral/Completa
    - Copia todos os dados
    - Implica maior tempo de cópia (o que prejudica o RPO)
    - Implica menor tempo de reposição (o que beneficia o WRT)
  - Incremental
    - Necessita sempre de uma cópia integral/completa prévia
    - Copia todos os dados que foram alterados desde a cópia incremental anterior (ou a integral se for a primeira)

Business Continuity Management

- A cópia de segurança tem três estratégias possíveis (ii)
  - Diferencial
    - Necessita sempre de uma cópia integral/completa prévia
    - Copia todos os dados que foram alterados desde a cópia integral anterior
- Qual a melhor estratégia tendo em mente o RPO, o RTO e o WRT?
  - Depende…
    - Do ambiente de execução…
    - Da possibilidade de manter ou não o sistema em funcionamento durante a execução da cópia…

Business Continuity Management

- Se a estratégia possível for a cópia de segurança, qualquer que seja a sua metodologia,
  - Deve ser sempre feita em duplicado
  - Um dos meios que contém a cópia deve ser guardado num local remoto
  - …
  - E não esquecer que aleatoriamente deve ser verificada a cópia e a capacidade de reposição dos dados!